

SOC HOME LAB

Complete Interview Preparation Guide

Threat Detection Environment — Architecture, Deep Dives, Q&A Bank

Shahid Ahmad Malik
Aspiring SOC Analyst | B.Tech CSE

Prepared for interview revision — July 2026

How To Use This Document

This is your single reference for talking about the SOC Home Lab project in interviews. It's built directly from your own project notes and current progress — including the parts that aren't finished yet.

- Section 1: A tight elevator pitch you can say in 30 seconds.
- Section 2: The architecture, laid out the way an interviewer will probe it.
- Section 3: A deep dive on every component — why you built it that way, not just what it does.
- Section 4: 80+ realistic interview questions with answers written in first person, ready to adapt in your own words.
- Section 5: An honest status check — what's done, what's in progress, what's still pending.
- Section 6: A cheat sheet — event codes, SPL queries, IPs — for last-minute revision.

One important note baked into this whole document: Sysmon is confirmed working on DC01, but you ran into unresolved errors getting it stable on PC01 and PC02. That's treated here as a real, current fact — not smoothed over — because it's actually a strong story about troubleshooting, not a weakness to hide.

1. The 30-Second Elevator Pitch

Memorize the shape of this, not the exact words:

“I built a SOC home lab from scratch to get real hands-on experience instead of just certifications. It's a simulated enterprise network in VMware — a Windows Server 2022 domain controller running Active Directory, DNS and DHCP, two domain-joined workstations, and an Ubuntu box running Splunk Enterprise as the SIEM. I forward Windows Event Logs and Sysmon telemetry into Splunk, built an 8-panel SOC dashboard, and wrote a brute-force detection alert. Then I simulated an actual attack from Kali Linux — an Nmap scan followed by a Hydra brute-force against the Administrator account — and detected it in Splunk using EventCode 4625, and wrote it up as a full incident report with a MITRE ATT&CK mapping. It's still evolving — I'm currently working through some Sysmon deployment issues on the workstations — but the core detection pipeline is live and working.”

That last sentence matters. Don't hide the Sysmon issue in the pitch — mentioning it briefly and confidently signals you understand the project's real state, which is exactly what a SOC manager wants to see.

2. Architecture At A Glance

Draw this from memory if asked — interviewers love a whiteboard moment:

Component	Role	IP Address	OS
DC01	Domain Controller + AD DS + DNS + DHCP	192.168.160.10	Windows Server 20
PC01	Domain-joined workstation (attack target)	192.168.160.20	Windows 10 Pro
PC02	Domain-joined workstation	192.168.160.30	Windows 11 Enterp
Ubuntu / Splunk	SIEM — indexer + search head	192.168.160.x (DHCP)	Ubuntu Desktop 24
Kali Linux	Attacker machine	DHCP-assigned	Kali 2026.1
Metasploitable2	Vulnerable target (available, not yet used in a documented attack)	DHCP-assigned	Linux

- Domain: securecorp.local — a fictional company name, deliberately realistic rather than "test.local".
- Network: 192.168.160.0/24, gateway 192.168.160.2, all VMs on VMware NAT (not Bridged — see Networking Q&A for why).
- DHCP scope: 192.168.160.100–200, 8-day lease, handed out to anything that isn't statically addressed.
- Log flow: Windows Event Logs + Sysmon → Splunk Universal Forwarder → port 9997 → Splunk indexer on Ubuntu → index=main.

3. Component Deep Dives

3.1 Virtualization Layer — VMware Workstation

Everything runs on one physical laptop (16GB RAM, Ryzen 5 5500U, 474GB SSD) using VMware Workstation, not VirtualBox. That switch itself is a talking point — VirtualBox had boot failures with Windows 11's UEFI/TPM requirements, and VMware handled Secure Boot and TPM 2.0 emulation cleanly.

Networking mode was a deliberate decision: NAT instead of Bridged. On a mobile hotspot (Jio 5G), Bridged mode caused adapter conflicts because the VMs were competing for a DHCP lease on the same physical network as the phone hotspot. NAT lets every VM share the host's single internet connection through VMware's virtual router while still letting VMs talk to each other on the internal 192.168.160.0/24 segment — which is really all a home lab needs, since nothing here has to be reachable from the outside.

RAM budgeting mattered more than expected: 6 VMs at their allocated sizes ($4+4+4+4+2+1 = 19\text{GB}$) don't all run simultaneously on a 16GB host, so machines get paused/suspended rather than all run live — a real constraint that mirrors resource planning conversations SOC teams have about lab and staging environments.

3.2 Domain Controller (DC01) & Active Directory

DC01 is a Windows Server 2022 Standard Evaluation install with the Desktop Experience (GUI), given a static IP (192.168.160.10) before anything else — a DC's IP has to never change, because every other machine in the domain hardcodes it as their DNS server.

AD DS (Active Directory Domain Services) was installed through Server Manager's Add Roles and Features wizard, then the server was promoted to a domain controller as a brand-new forest, root domain `securecorp.local`, at the default forest/domain functional level. One deliberate mistake worth mentioning in interviews: the first attempt accidentally installed AD CS (Certificate Services) instead of AD DS — they sound similar in the role list but do completely different jobs. AD CS issues and manages digital certificates (PKI); AD DS is the actual directory service that stores users, computers, and group policy. That got caught, AD CS was removed, and AD DS was installed correctly.

Verification after promotion used `whoami` (confirmed `securecorp\administrator`) and `dcdiag /summary` (all tests passed) — `dcdiag` is the standard health-check tool for a DC and it's worth being able to name a few of the tests it runs (Advertising, Replications, SysVolCheck, NetLogons) even at a surface level.

3.3 DNS & DHCP

DNS was installed automatically as part of AD DS — Active Directory is DNS-integrated, meaning DC01's DNS server holds AD-integrated zones and every domain-joined machine has to point at it, not at a public resolver, or authentication and Group Policy break. Verified with `nslookup securecorp.local` resolving to 192.168.160.10.

DHCP was added as a separate role, authorized, and given one scope: `SecHomeLab_Scope`, range .100–.200, gateway .2, DNS .10, 8-day lease. Static reservations weren't used for the servers — DC01, PC01 and PC02 all just have manually-configured static IPs outside the DHCP range entirely, which is the simpler and more common real-world pattern for infrastructure that must never move.

3.4 Workstations — PC01 & PC02

PC01 runs Windows 10 Pro specifically because Windows 10 Home cannot join a domain — that's a Home vs Pro licensing limitation, not a technical bug, and it's exactly the kind of gotcha that wastes hours if you don't already know it (which is how it ended up in the issues log here). PC02 runs Windows 11 Enterprise, which required enabling UEFI and TPM 2.0 in VMware's VM settings before install — Windows 11 hard-requires TPM 2.0, and a straightforward download of the wrong architecture ISO (ARM64 vs x64) caused an earlier boot failure that had to be re-downloaded and rebuilt.

Both machines got static IPs (.20 and .30), were renamed, and joined to securecorp.local via System Properties → Change → Domain, authenticating as Administrator. PC01's domain join is fully verified (whoami returns securecorp\administrator, systeminfo confirms Domain: securecorp.local) and it has the Splunk Universal Forwarder installed and sending logs. PC02's domain join and forwarder installation are the two pending items — PC02 exists and is built, but hasn't been walked through the same verification and forwarder steps as PC01 yet.

3.5 Splunk SIEM

Splunk Enterprise runs on Ubuntu Desktop 24.04, installed from the official .deb package with `dpkg -i`, started and license-accepted via the CLI, and set to boot-start so it survives a VM reboot without manual intervention. Splunk's web UI runs on port 8000; the receiving port for forwarded data is 9997, configured under Settings → Forwarding and Receiving → Configure Receiving.

On the Windows side, the Splunk Universal Forwarder (a separate, lightweight package from full Splunk) is installed on DC01 and PC01, pointed at the Ubuntu box's IP on port 9997. The actual log selection is controlled by `inputs.conf`, hand-edited at `C:\Program Files\SplunkUniversalForwarder\etc\system\local\inputs.conf`, enabling the Security, System, and Application Windows Event Log channels (plus the Sysmon operational channel once Sysmon is installed) into `index=main`. Every config change to `inputs.conf` requires restarting the forwarder service before it takes effect — that's a genuinely common trip-up worth mentioning.

All data lands in a single index, `main`, distinguished by host and source rather than by separate indexes — fine for a small lab, and a good springboard if asked how this would change at enterprise scale (see the curveball Q&A section).

3.6 Sysmon — What's Actually Working, and What Isn't

This is the section to be completely upfront about, because it's the most current, most "live" part of the project.

Sysmon (System Monitor, a Sysinternals tool) was installed on DC01 using the SwiftOnSecurity community config (`sysmonconfig-export.xml`) — an industry-recognized baseline that a lot of real security teams start from rather than writing detection rules from scratch. On DC01, the service installs and runs cleanly: `sc query sysmon64` shows `STATE: RUNNING`, and its events (particularly Event ID 1 for process creation, 3 for network connections, and 22 for DNS queries) are visible in Event Viewer under Applications and Services Logs → Microsoft-Windows-Sysmon/Operational.

On PC01 and PC02, the same install steps have not produced a stable result yet, and this is genuinely still being troubleshooted rather than solved. The honest way to talk about this in an interview is to describe the process, not to claim a fix that hasn't happened. Worth having ready as your own words: what you tried, and

the leading suspects you're chasing next — driver installation being blocked (Sysmon installs a minifilter/kernel driver, which needs local admin and can be blocked by driver signature enforcement or endpoint protection intercepting it on a workstation image that DC01 didn't have); the config XML not applying correctly on a second attempt (Sysmon needs -c to update an existing config, not another -i, or it errors out claim already installed); the Sysmon operational log channel not appearing in Event Viewer at all, which usually means the service silently failed to start rather than a config problem; and inputs.conf/forwarder restart being missed after installing Sysmon on the workstation, so even if the service were running, Splunk wouldn't see it without editing inputs.conf and restarting the forwarder.

The interview-safe way to frame this: “I got it working end-to-end on the domain controller first, which proved out the pipeline — install, config, service running, events forwarding to Splunk. Rolling the identical steps to the workstations hasn't gone as smoothly, and I'm currently isolating whether it's a driver/permissions issue or a forwarder-side config issue before I reinstall blind.” That's a real SOC analyst answer — isolate variables, don't just retry the same thing hoping it works.

3.7 Attack Simulation — Nmap + Hydra

From Kali Linux (credentials kali/kali, pre-installed in the lab), two tools simulated an actual attacker's early kill-chain steps against PC01:

- Nmap (nmap -sV -O <PC01 IP>) — service version detection and OS fingerprinting, i.e., reconnaissance. This maps to MITRE T1046, Network Service Scanning.
- Hydra (hydra -l administrator -P rockyou.txt smb://<PC01 IP>) — an automated password-guessing attack against SMB, targeting the built-in Administrator account specifically because local admin and domain admin accounts are the highest-value brute-force targets in any real environment. Maps to MITRE T1110 (Brute Force) and T1078 (Valid Accounts).

The attack was intentionally aimed at PC01 rather than DC01 — attacking a workstation rather than the domain controller directly is more realistic; real attackers usually land on an endpoint first and move laterally, they don't walk straight up to the DC.

3.8 Detection — EventCode 4625 and the Brute-Force Alert

Windows logs every failed logon as Security EventCode 4625, and Splunk was searched with index=main host=PC01 EventCode=4625 to pull them. The fields that actually matter for an investigation, and that came back in the results: Account_Name (administrator — confirms the target), Failure_Reason (Unknown user name or bad password), Logon_Type (3 — a network logon, as opposed to Type 2 interactive/console or Type 10 RDP, which immediately tells you this wasn't someone sitting at the keyboard), and Logon_Process (NtLmSsp — meaning NTLM authentication was used, not Kerberos, which is itself worth a mention since NTLM over the network is exactly the kind of legacy auth a real SOC would flag for hardening).

The detection rule built on top of this: index=main EventCode=4625 | stats count by Account_Name | where count > 5, scheduled every 5 minutes, severity High. Five failures is a deliberately low, aggressive threshold appropriate for a lab; a real production environment would tune this against baseline noise (users who mistype passwords) and probably pair a count threshold with a time window (stats count by Account_Name in a rolling 5-minute bucket) to avoid false positives from someone who just forgot their password once that morning.

3.9 SOC Monitoring Dashboard

An 8-panel dashboard was built in Splunk covering, end to end, the story an analyst needs on one screen: failed logins over time (line chart, by host), successful logins (bar chart, by account), new process creation from Sysmon Event ID 1 (table), network connections from Sysmon Event ID 3 (table), top targeted accounts (pie chart), DNS queries from Sysmon Event ID 22 (table), a unified security events timeline built with an eval/case statement that labels each EventCode into a human-readable category, and a critical events table watching for account/group changes and audit log clearing (EventCodes 4720, 4728, 4732, 1102 — that last one, audit log cleared, is a classic anti-forensics red flag worth calling out by name if asked).

Three alert rules sit alongside the dashboard: brute-force detection (described above), new admin account creation (EventCode 4720/4728, hourly), and suspicious PowerShell execution (Sysmon Event ID 1 where the image path contains powershell, real-time). The PowerShell alert is a good one to be able to explain: attackers frequently use PowerShell for post-exploitation because it's a trusted, signed Windows binary that blends into normal admin activity — which is exactly why the alert exists, and exactly why it currently depends on Sysmon reaching the workstation it's supposed to watch.

3.10 Incident Response Report — IR-001

A full write-up was produced in the standard incident-report shape: summary, detection method, evidence collected, attack timeline, impact assessment, MITRE ATT&CK mapping, and recommendations. Impact assessment concluded no compromise (attack failed, no access gained) — which matters, because part of an IR report's job is separating “something alarming happened” from “something alarming happened and it worked.” Recommendations included account lockout policy, MFA for admin accounts, continuous monitoring of 4625, IP blocking at the firewall, network segmentation, and a stronger password policy (14+ characters, complexity) — the standard, defensible response to a brute-force finding.

VM snapshots (DC01_Baseline_Clean, PC01_Baseline_Clean, Ubuntu_Splunk_Baseline, Kali_Baseline_Clean) were taken after this to preserve a known-good state — explicitly learned the hard way, after earlier rebuilds cost time. This is good material for a “what would you do differently” answer: snapshot before every major change, not after.

4. Interview Question & Answer Bank

Answers are written the way you'd actually say them — adapt the wording to sound like you, not like a script.

A. Project Overview & Motivation

Q: Why did you build a home lab instead of just doing more certifications?

A: Certs prove I can pass a multiple-choice test. This proves I can actually stand up a domain, break it, watch the logs, and fix it — which is closer to what the job actually is. I wanted something I could talk about in detail instead of reciting a syllabus.

Q: Walk me through your project in two minutes.

A: It's a simulated small enterprise network — a domain controller running AD, DNS and DHCP, two Windows workstations joined to that domain, and a Splunk server collecting logs from all of it. I forward Windows Event Logs and Sysmon telemetry in, built an 8-panel dashboard and a brute-force alert, then simulated an actual attack from Kali — an Nmap scan and a Hydra brute-force against the admin account on one of the workstations — and detected and documented it end to end, including a full incident report with MITRE mapping. Sysmon's fully working on the DC but I'm still sorting out issues getting it stable on the two workstations.

Q: What was the single hardest part of this project?

A: Getting Sysmon reliably running on the workstations, honestly. It went in cleanly on the domain controller first try, so I know the process works — but the same steps on PC01 and PC02 haven't landed yet, and I'm working through whether it's a driver/permission issue on the VM or something on the forwarder side.

Q: What would you build next if you kept going?

A: Finish Sysmon on both workstations, get PC02 fully domain-joined and forwarding, and then add a second detection scenario — something like a scheduled-task persistence technique or a suspicious PowerShell download — so the lab isn't just brute-force detection, it's a small library of detections.

Q: Why Splunk specifically, and not something like Wazuh or the ELK stack?

A: Splunk is what the majority of SOC job postings actually list, and it has a free Enterprise trial that's more than enough for a home lab. I wanted to learn the tool I'd actually be expected to use on day one, not just a SIEM concept in the abstract.

B. Active Directory & Windows Server

Q: What is Active Directory and what does it actually do in your lab?

A: It's Microsoft's directory service — it centrally manages user accounts, computer accounts, and the policies that apply to them. In my lab it's the thing that makes PC01 and PC02 part of one logical domain, securecorp.local, so there's one Administrator account and one authentication authority instead of each machine managing its own local accounts.

Q: What's the difference between AD DS and AD CS? You mentioned mixing them up.

A: AD DS is Domain Services — the actual directory: users, computers, group policy, authentication. AD CS is Certificate Services — it issues and manages digital certificates for things like encrypting traffic or smart card auth. I installed AD CS by mistake the first time because they're right next to each other in the Server Manager role list and the names are easy to confuse under pressure. I removed it and installed AD DS correctly, but it taught me to slow down and read the role description before clicking Install.

Q: How did you verify DC01 was actually working correctly as a domain controller?

A: Two commands: `whoami`, which should return `securecorp\administrator` once you're authenticated to the domain, and `dcdiag /summary`, which is the standard Microsoft health-check tool for a DC — it runs a batch of tests like Advertising, Replications, and NetLogons and tells you pass/fail on each. Mine came back all green.

Q: Why does Windows 10 Home fail to join a domain?

A: It's a licensing/edition restriction, not a bug — Home edition simply doesn't ship the domain-join, Group Policy, or BitLocker features that Pro and Enterprise have. I hit this directly: built PC01 on Home first, it wouldn't offer the domain join option at all, and had to rebuild on Windows 10 Pro.

Q: What's a forest, and did you create a new one or join an existing one?

A: A forest is the top-level container in AD's structure — one or more domains sharing a common schema and trust relationship. I created a brand new forest with `securecorp.local` as the root domain, since this was a from-scratch lab with no existing AD to join.

Q: What's the difference between a DSRM password and the domain Administrator password?

A: DSRM — Directory Services Restore Mode — is a special local recovery password on the DC itself, used to boot into a restore mode if AD DS becomes corrupted and you need to work on the database offline. It's separate from the domain Administrator account on purpose, so you have a way in even if AD itself is broken.

Q: If PC01 couldn't join the domain, what would you check first?

A: DNS, before anything else. Domain join depends on the workstation being able to resolve the domain and find the DC via SRV records, so if the workstation's DNS isn't pointed at the DC, the join fails with a credentials-looking error that's actually a name resolution problem. That's exactly what happened to me on PC01 — the join kept failing until I fixed the preferred DNS server to point at `192.168.160.10`.

C. Networking — DNS, DHCP, TCP/IP

Q: Explain DNS in your lab in your own words.

A: DNS translates names to IP addresses — `dc01.securecorp.local` resolves to `192.168.160.10`. It came installed automatically with AD DS because AD is DNS-integrated; the DC hosts the zone for the domain, and every domain member has to use it as their DNS server or things like Group Policy and domain login break.

Q: Explain DHCP and why you scoped it the way you did.

A: DHCP hands out IP addresses automatically so machines don't need manual configuration — I scoped it `.100` to `.200` with an 8-day lease. I deliberately kept the servers (DC01, PC01, PC02) outside that range with static IPs, because infrastructure that other machines depend on for DNS or authentication can't have its address change underneath everyone.

Q: Why NAT instead of Bridged networking in VMware?

A: I was working off a mobile hotspot, and Bridged mode put every VM directly on the same physical network as the hotspot, which caused adapter conflicts. NAT lets all the VMs share the host's one internet connection through VMware's internal router while still letting the VMs reach each other — which is really all a self-contained lab needs anyway.

Q: What's the difference between a static IP and a DHCP-assigned one, and why do servers need static?

A: DHCP leases can change when they expire or renew; a static IP is fixed until someone manually changes it. Servers need static addressing because other machines hardcode their address — my workstations point at 192.168.160.10 as their DNS server, so if that IP moved, every domain-joined machine would break.

Q: Walk me through what happens on the network when PC01 boots up and logs in.

A: PC01 already has a static IP, so no DHCP negotiation there. It sends a DNS query to 192.168.160.10 to locate the domain controller via SRV records, then authenticates — in my case over NTLM (Logon Type 3 network logon in the security log) rather than Kerberos, which shows up in the 4624/4625 events I was searching in Splunk.

Q: What does Logon Type 3 mean, and why does it matter for detection?

A: Type 3 is a network logon — no one's sitting at the console, it's a connection coming in over the network, like SMB. It matters for detection because it immediately tells you the failed logins I was investigating were a remote brute-force attempt (Hydra hitting SMB), not someone at the keyboard fat-fingering their password.

D. Splunk / SIEM

Q: What is Splunk and what problem does it solve?

A: It's a SIEM — it centralizes logs from every machine in the environment into one searchable place, so instead of RDP-ing into five machines to check Event Viewer one at a time, I run one search across all of them. That's the whole value proposition of a SIEM: correlation and speed.

Q: How does data actually get from a Windows machine into Splunk?

A: The Universal Forwarder — a lightweight agent, separate from full Splunk — reads whatever's defined in inputs.conf (in my case Security, System, Application, and the Sysmon operational channel) and ships it to the indexer on port 9997. The indexer, running on my Ubuntu box, receives it and stores it under index=main.

Q: What's the difference between the Universal Forwarder and full Splunk Enterprise?

A: The Forwarder is deliberately minimal — it collects and forwards data, it doesn't index or let you search. Full Splunk Enterprise, which I run on Ubuntu, does the indexing, storage, search, dashboards and alerting. You wouldn't put full Enterprise on every endpoint; it's too heavy and it's not what endpoints are for.

Q: What's an index, and why did you use just one?

A: An index is a data store within Splunk — you can separate data by index for retention policy or access control reasons. I used a single index=main because this is a small lab; at real scale I'd split by data type or

business unit, e.g. a separate index for endpoint logs versus firewall logs, partly for performance and partly so access can be scoped per team.

Q: Write me the SPL to find all failed logins on PC01.

A: `index=main host=PC01 EventCode=4625` — that's the baseline search. If I want it summarized: `index=main host=PC01 EventCode=4625 | stats count by Account_Name | sort -count`.

Q: How would you tune your brute-force alert to reduce false positives?

A: Right now it's just `count>5` with no time bound, which in a real environment would fire on a user who mistypes their password across a whole afternoon. I'd bucket it with a time window — `stats count by Account_Name over a rolling 5-minute span using bin/timechart` — so it only fires on rapid repeated failures, which is the actual signature of an automated tool like Hydra rather than human error.

Q: What's the difference between a report, an alert, and a dashboard panel in Splunk?

A: A report is a saved search. A dashboard panel visualizes a search's results on a screen, live or scheduled. An alert is a scheduled search with a trigger condition — mine runs every 5 minutes and fires when the failed-login count exceeds 5 — and an action attached to it, like an email or, in a real SOC, a ticket into the case management system.

Q: What is sourcetype and how is it different from index?

A: Sourcetype tells Splunk how to parse a piece of data — it defines the field extractions, timestamp format, and event boundaries for something like `WinEventLog:Security` versus a Sysmon XML event. Index is just where the data physically lives. Two different sourcetypes can happily live in the same index, which is exactly what's happening in my single main index right now.

Q: If your forwarder stopped sending logs, how would you troubleshoot it?

A: Check the forwarder service is actually running (`sc query SplunkForwarder` on Windows), confirm 9997 is reachable from the endpoint to the indexer, check `inputs.conf` for typos or a channel that's disabled, and check the indexer's Configure Receiving setting is still enabled on port 9997. I hit a version of this directly — my forwarder wasn't sending until I manually recreated `inputs.conf` in the right directory and restarted the service, which is now just muscle memory.

Q: How would this architecture change if you had 500 endpoints instead of 2?

A: Single index and single indexer wouldn't hold up — I'd move to a distributed setup with multiple indexers behind a load-balanced set of forwarders, use index-time field extraction sparingly for performance, split data across multiple indexes by data type/retention, and almost certainly deploy configs via a Deployment Server instead of hand-editing `inputs.conf` on every machine, which is exactly what I'm doing by hand in the lab.

E. Sysmon & Endpoint Logging

Q: What is Sysmon and why isn't native Windows logging enough?

A: Sysmon is a Sysinternals tool that logs far more detail than default Windows auditing — full process command lines, parent-child process relationships, network connections with source and destination, DNS queries, registry changes. Native Windows logging can tell you a process ran; Sysmon tells you what it ran, what launched it, and what it talked to on the network, which is the level of detail actual detection engineering needs.

Q: Which Sysmon Event IDs do you know, and why do they matter?

A: ID 1 is process creation — the core one, full command line and parent process. ID 3 is network connection — source/destination IP and port, useful for spotting C2 traffic. ID 11 is file creation, useful for catching dropped payloads. ID 22 is DNS query, useful for catching lookups to known-bad or newly-registered domains. Those four cover most of what I built the dashboard panels around.

Q: Is Sysmon working across your whole lab right now?

A: No, and I want to be direct about that — it's fully working on DC01: service running, config applied, events flowing into Splunk. On PC01 and PC02 it isn't stable yet. I'm still isolating whether that's a driver/permissions issue on the VM image or something on the forwarder/inputs.conf side.

Q: What have you actually tried to fix Sysmon on the workstations?

A: Reinstalling with the same command and config that worked on DC01, checking the service state with `sc query sysmon64`, and checking whether the Sysmon operational log even appears under Applications and Services Logs in Event Viewer. If the channel isn't there at all, that points to the service failing to start rather than a config file problem — which is the direction I'm leaning, since Sysmon installs a kernel driver and that install step is the most likely thing to behave differently between a server build and a workstation build.

Q: What's your theory on why it worked on the server but not the workstations?

A: My leading suspects are driver installation permissions — Sysmon needs to load a minifilter driver, and that can be blocked depending on local security policy, Secure Boot/driver signature settings, or something the endpoint's install process didn't account for — and separately, even if the service is fine, forgetting to add the Sysmon channel into `inputs.conf` and restart the forwarder would make it look like Sysmon 'isn't working' when it's actually a Splunk-side visibility gap, not a Sysmon problem at all. Part of what I still need to do is separate those two possibilities before assuming a fix worked.

Q: Why does this matter for a real SOC role, not just for finishing the checklist?

A: Because half of SOC work is exactly this — a data source silently stops flowing and you have to work out whether it's the endpoint, the agent, the network path, or the receiving end, without breaking anything else that's currently working. Being able to describe that process clearly, mid-investigation, is arguably more useful to show an interviewer than a lab where nothing ever went wrong.

Q: Which config are you using for Sysmon and why that one?

A: The SwiftOnSecurity `sysmonconfig-export.xml` — it's a well-known, widely used community baseline rather than something built from zero. It's a sensible default for a lab and it's genuinely used as a starting point by real security teams before they tune it to their own environment.

F. Attack Simulation & Detection

Q: Why did you attack PC01 and not DC01 directly?

A: It's more realistic. Attackers almost never walk straight up to a domain controller — they land on a regular endpoint first and try to move laterally or escalate from there. Targeting the workstation mirrors an actual initial-access scenario better than targeting the DC would.

Q: What does `nmap -sV -O` actually do?

A: -sV does service version detection on open ports — so instead of just 'port 445 open' it tries to tell you what's actually listening and what version. -O attempts OS fingerprinting based on how the TCP/IP stack responds. Together it's classic reconnaissance — mapping what's alive and what it's running before deciding how to attack it.

Q: Walk me through the Hydra command you used.

A: `hydra -l administrator -P /usr/share/wordlists/rockyou.txt smb://<PC01 IP>` — -l fixes the username to administrator specifically, since that's the highest-value account to target; -P points at a password wordlist (rockyou.txt, a very standard one bundled with Kali) and Hydra tries them one after another against SMB on PC01.

Q: How did you know the attack in Splunk was a brute force and not just a normal user mistyping their password?

A: Volume and speed — many EventCode 4625 failures in a very short window, all against the same account, all Logon Type 3 (network) using NtLmSsp. A real user fat-fingering their password produces maybe one or two failures spread out; this was a rapid burst from an automated tool, which is the actual signature I was looking for.

Q: Which MITRE ATT&CK techniques map to this attack, and why those?

A: T1046, Network Service Scanning, for the Nmap phase — that's reconnaissance. T1110, Brute Force, for the Hydra phase — that's credential access. And T1078, Valid Accounts, because the target was a legitimate built-in account (Administrator) rather than a fabricated one, which is exactly the technique real attackers use once they've brute-forced their way to a working credential.

Q: What was the actual impact of this attack?

A: None — that's an important part of the incident report, not an afterthought. No credentials were successfully guessed, no access was gained, nothing was disrupted. Concluding 'attack attempted, defenses held' is a real and useful outcome to document; not every incident report ends in a breach.

Q: What would you do differently if Hydra had actually succeeded?

A: The incident response would shift completely — from monitoring/detection into containment: isolate PC01 from the network, force a password reset on the compromised account domain-wide if it was a shared/admin credential, check for lateral movement using Sysmon's process and network events, and only then move into root cause and remediation.

Q: How would an attacker have evaded this specific detection?

A: Slowing the attack down below the 5-failures threshold, spreading attempts across a longer time window, or rotating which account they target instead of hammering one — all reasons a real detection rule needs a time-bounded threshold and ideally correlation across multiple accounts from the same source, not just a flat count.

G. Dashboards & Alerting

Q: Why 8 panels — how did you decide what to include?

A: I wanted one screen to answer the questions an analyst actually asks first: who's failing to log in, who's succeeding, what new processes are running, what's talking on the network, who's being targeted the most,

what DNS lookups are happening, a timeline of everything together, and a table of the genuinely critical stuff — account/group changes and cleared audit logs — that should never be buried in a general feed.

Q: Why is EventCode 1102 (audit log cleared) on your critical events panel?

A: Because clearing the audit log is a classic anti-forensics move — an attacker or a malicious insider covering their tracks. It's rare enough in normal operation that it deserves its own visibility rather than getting lost in a general security event feed, so I gave it a dedicated place on the critical panel instead of relying on someone to search for it.

Q: What's the difference between your three alert rules?

A: Brute-force detection (EventCode 4625, count>5, every 5 minutes, High) watches for credential attacks. New admin account creation (4720/4728, hourly, Critical) watches for privilege escalation via account changes. Suspicious PowerShell (Sysmon ID 1 where the image path contains powershell, real-time, High) watches for a common post-exploitation tool. They're deliberately different severities and schedules because they represent different stages of an attack and different urgency levels.

Q: Why is the PowerShell alert real-time but the brute-force alert only every 5 minutes?

A: PowerShell execution matching that pattern is a stronger, rarer signal that warrants immediate attention — if it's real it could mean an attacker already has a foothold and is executing commands. Failed logins are noisier and more tolerant of a short delay before you need to know about them, so a 5-minute cadence is a reasonable balance between speed and not overloading the search head.

Q: Right now, does the PowerShell alert actually work on your workstations?

A: It's built and would work as soon as Sysmon is stable there, since it depends on Sysmon Event ID 1. That's actually the clearest practical reason finishing the Sysmon rollout matters — it's not just a checklist item, it directly blocks one of my three alert rules from having anything to alert on.

H. Incident Response

Q: Walk me through your incident report structure.

A: Summary, detection method, evidence collected, attack timeline, impact assessment, MITRE mapping, and recommendations — that's a fairly standard IR report shape, and I used it deliberately so the document reads like something a real SOC would file, not just a lab writeup.

Q: What evidence did you collect and why does each piece matter?

A: EventCode, account name, failure reason, logon type, logon process, and source — together those tell a complete story: who was targeted, how the attempt was made (network logon, NTLM), and that it was repeated rather than a one-off. Any one of those alone is a data point; together they're an investigation.

Q: Why take VM snapshots after finishing the investigation instead of before?

A: Honestly, that was a lesson learned the hard way — I hadn't been snapshotting consistently earlier in the project and had to rebuild a couple of machines from scratch after breaking a configuration. So the snapshots after this incident were partly to preserve the clean, working state going forward. If I were starting over, I'd snapshot before every major change, not just after a milestone.

Q: What recommendations did you make, and would they actually have stopped this attack?

A: Account lockout after 5 failed attempts would stop Hydra cold — it would lock the account long before a large wordlist got anywhere. MFA on admin accounts would mean even a correct password guess isn't enough. The others — monitoring, IP blocking, segmentation, password policy — are more about defense in depth and limiting blast radius rather than a single silver bullet.

Q: If this had been a real company, who would you have escalated this to, and how?

A: Depends on severity policy, but a High-severity brute-force with no successful access would typically go to a Tier 2 analyst or the team lead for awareness, with a ticket documenting it — not necessarily a 3am page. If it had shown a successful login after the failures, that changes immediately to an active-incident escalation.

I. Troubleshooting & Challenges

Q: What's the most useful mistake you made on this project?

A: Installing AD CS instead of AD DS. It cost time to undo, but it forced me to actually understand the difference between the two instead of just clicking through a wizard — which is exactly the kind of thing that's easy to explain clearly now because I lived through the confusion.

Q: Tell me about a problem you haven't fully solved yet.

A: Sysmon on PC01 and PC02. It's fully working on the domain controller, so the process itself is proven, but the same steps haven't produced a stable result on the workstations, and I'm currently narrowing down whether it's a driver/permissions issue at install time or something on the Splunk forwarder side that's hiding a working install. I'd rather describe that accurately than claim it's finished.

Q: Describe a time you had to debug something with almost no information to go on.

A: PC01's domain join kept failing with what looked like a credentials error, but the actual root cause was DNS — the workstation wasn't pointed at the domain controller for name resolution, so it couldn't even locate the domain to authenticate against. The error message pointed at the wrong layer entirely, which taught me to check DNS early whenever a domain-related operation fails in a way that doesn't quite make sense.

Q: How do you approach a problem when your first fix attempt doesn't work?

A: Change one variable at a time and verify at each step, rather than changing five things and hoping. With the Splunk forwarder issue, I didn't just reinstall blindly — I checked the service state, then the config file, then the port, then the receiving-end setting, one at a time, until I found the actual break.

Q: What's a mistake you made that you'd avoid next time?

A: Not snapshotting VMs before major changes early on. I rebuilt more than one machine from scratch because a misconfiguration broke something and I had no clean rollback point. Cheap insurance I skipped until it cost me real time.

Q: If you only had one more hour on this project, what would you spend it on?

A: Checking whether the Sysmon operational log channel is even present in Event Viewer on PC01. That single check tells me immediately whether I'm chasing a service/driver problem or a Splunk-visibility problem, and it's the fastest way to stop guessing and start fixing the right thing.

J. Behavioral — Connecting Support Experience to SOC Work

Q: You've mostly worked in customer support — why should we believe you can handle SOC work?

A: SOC work and Tier 1 support have more in common than people assume — both are triage-driven: you get an alert or a ticket, you have limited initial information, you follow a process to gather more, and you decide whether to escalate. At IEnergizer I handled sensitive account queries for a payments platform under process-adherent, security-conscious standards, and at Startek I ran Tier 1 hardware/software troubleshooting through a ticketing system with proper escalation paths. That's the same discipline a SOC needs — just pointed at security events instead of billing questions.

Q: Tell me about a time you had to stay calm and methodical under pressure.

A: Working payments-related support, a wrong or rushed answer has real consequences, so I got used to slowing down, verifying before acting, and following the process even when a customer wanted an instant answer. That translates directly to not jumping to conclusions on a security alert before you've actually verified what it is.

Q: How do you handle repetitive work — won't SOC alert triage get monotonous?

A: Tier 1 support is genuinely repetitive too, and the way I stayed sharp was treating each ticket as its own small investigation rather than going on autopilot. I built this whole home lab specifically because I wanted more of that investigative side, not less — the brute-force detection, tracing it through logs, writing the report, all of that is the part of the work I find genuinely interesting.

Q: What do you do when you don't know the answer to something during an investigation?

A: Say so, then go find out — same as troubleshooting an Acer laptop issue I hadn't seen before at Startek. I'd rather escalate or research properly than guess and give someone false confidence, and that's exactly the instinct I want in a SOC role, where a wrong call can mean missing a real incident.

Q: Why the move from support into security specifically?

A: Support taught me the process discipline and the customer/business-impact side of IT. Security is the part I actually want to go deep on — I started with TryHackMe, then wanted something bigger than isolated rooms, so I built this lab to connect all of it into one environment I actually understand end to end, not just a checklist of completed rooms.

K. Curveball & Deep-Technical Questions

Q: If I gave you raw pcap of this Hydra attack, what would you look for?

A: Repeated SMB (port 445) connection attempts from a single source IP to PC01 in rapid succession, each with an SMB authentication negotiation and failure — the network-layer fingerprint of what Splunk was showing me at the log layer. High connection frequency to one destination, one port, from one source is the giveaway.

Q: Kerberos vs NTLM — which did your lab use, and why does it matter?

A: My logon events showed NtLmSsp, meaning NTLM, not Kerberos — likely because the SMB-based Hydra attack against an IP address rather than a hostname doesn't negotiate Kerberos the way an interactive domain logon usually would. It matters because NTLM is older, weaker, and vulnerable to relay attacks; a real hardening recommendation coming out of this incident would include reducing NTLM usage in favor of Kerberos where possible.

Q: What's the risk of a single index=main design at scale, beyond just performance?

A: Access control, mainly. In Splunk, permissions are often scoped at the index level — with everything in one index, you can't easily give a junior analyst read access to endpoint logs without also giving them firewall or DC logs. Splitting indexes by data type or sensitivity is how you'd fix that alongside the performance benefit.

Q: How would you detect the same brute-force attack without relying on EventCode 4625 alone?

A: Sysmon Event ID 3 could show repeated SMB connections from the same source in a short window, independent of whether Windows auth logging was even enabled — useful as a second, corroborating signal, and a good example of why you don't want to rely on a single log source for a single detection.

Q: What's a false positive your brute-force alert would currently generate, and how would you know?

A: A legitimate user who forgets their password and retries more than 5 times over an hour, or a service account with a stale credential retrying on a loop. I'd know by looking at the time distribution of the failures — spread out and human-paced versus tight and automated — which is exactly why I'd want to add a time-bounded window to the alert rather than a flat count.

Q: Why point DNS at DC01 with 8.8.8.8 as a fallback instead of just 8.8.8.8 as primary?

A: The domain-joined machines need DC01 as primary DNS to resolve internal AD records (SRV records, the domain itself) — a public resolver like 8.8.8.8 has no idea securecorp.local exists. 8.8.8.8 as the alternate is just there so general internet name resolution (this Ubuntu box's software updates, downloading Splunk, etc.) still works without a second internal DNS server.

Q: If DC01 went down right now, what breaks?

A: Everything that depends on domain authentication or internal name resolution — new domain logons, Group Policy application, and DNS resolution for anything under securecorp.local, since DC01 is currently the only DNS server in the environment. In a real environment that's exactly why you'd never run a single DC — redundancy through a second domain controller is a standard requirement I'd flag if this were a production design instead of a lab.

Q: What's one thing about this project you'd tell an interviewer you're not fully confident on yet?

A: Sysmon deployment on non-server Windows builds, specifically what's actually different about the workstation image that's blocking a clean install there. I understand the tool and the config well from getting it working on the DC — the workstation-specific troubleshooting is the piece I'm still actively building depth on.

5. Honest Status Check

Say this plainly if asked “is the project finished?” — a clear, confident “mostly, here's exactly what's left” lands far better than an evasive “yes.”

Fully working

- VMware lab: 6 VMs, NAT networking, all documented
- DC01: Windows Server 2022, AD DS, promoted to DC, domain securecorp.local
- DNS + DHCP configured and verified on DC01
- PC01: Windows 10 Pro, domain-joined, verified, Splunk Forwarder installed and sending logs
- Splunk Enterprise on Ubuntu: installed, receiving port 9997 configured
- Sysmon: fully installed, running, and forwarding on DC01
- Attack simulation: Nmap + Hydra from Kali against PC01, fully executed
- Detection: EventCode 4625 identified and investigated in Splunk
- 8-panel SOC dashboard: built and functioning
- 3 alert rules: built (brute-force and new-admin are fully functional now; PowerShell alert is built but has nothing to trigger on PC01/PC02 until Sysmon is stable there)
- Incident Report IR-001: written, with MITRE ATT&CK mapping
- VM snapshots: taken for all machines

In progress / pending

- Sysmon on PC01 and PC02 — not yet stable; actively troubleshooting driver/permissions vs. forwarder-config causes
- PC02: built and on the domain network, but domain join + Splunk Forwarder install not yet verified/completed
- GitHub portfolio repository — screenshots and README structure not yet fully populated
- Separate Log Analysis and Incident Response Playbook write-ups — planned, not started

None of this is a weakness to hide — a project that's 100% done with zero open issues is honestly less convincing in an interview than one where you can clearly explain what's left and why.

6. Quick-Reference Cheat Sheet

Windows Security Event Codes

Code	Meaning	Why it matters
4624	Successful logon	Baseline / confirm access after suspicious activity
4625	Failed logon	Core brute-force detection signal
4648	Logon using explicit credentials	Can indicate lateral movement / runas abuse
4688	New process created	Needs process-creation auditing enabled; execution visibility
4720	New user account created	Possible unauthorized account creation
4728	User added to global security group	Privilege escalation signal
4732	User added to local group	Privilege escalation signal
1102	Audit log cleared	Classic anti-forensics red flag

Sysmon Event IDs

ID	Meaning	Why it matters
1	Process creation	Full command line + parent process — core malware/exec detection
3	Network connection	Source/destination IP+port — C2 / lateral movement detection
7	Image/DLL loaded	DLL hijacking / sideloading detection
11	File created	Dropped payload / staging detection
12/13	Registry event / value set	Persistence mechanism detection
22	DNS query	Suspicious/newly-registered domain detection

SPL Queries To Have Memorized

- All events from a host: index=main host=PC01
- Failed logins: index=main EventCode=4625
- Failed logins by account, sorted: index=main EventCode=4625 | stats count by Account_Name | sort -count
- Brute-force alert logic: index=main EventCode=4625 | stats count by Account_Name | where count > 5
- Sysmon process creation: index=main EventCode=1 | table _time host User Image CommandLine
- Network connections: index=main EventCode=3 | table _time host SourceIp DestinationIp DestinationPort
- Event volume by type: index=main | stats count by EventCode | sort -count

- Timeline by host: index=main | timechart span=1h count by host

Core Facts

Item	Value
Domain	securecorp.local
Network range	192.168.160.0/24
Gateway	192.168.160.2
DHCP scope	192.168.160.100 – 192.168.160.200 (8-day lease)
DC01 IP	192.168.160.10 (DC, DNS, DHCP)
PC01 IP	192.168.160.20 (Windows 10 Pro, domain-joined, forwarder active)
PC02 IP	192.168.160.30 (Windows 11 Enterprise, domain join pending)
Splunk web UI	http://localhost:8000
Splunk receiving port	9997
Sysmon config	SwiftOnSecurity sysmonconfig-export.xml

End of document. Revise Sections 4 and 6 the night before an interview — everything else you already understand because you built it.